

Summary of Incident Timeline and Key Indicators Report

Table of Contents

Introduction
Incident Overview
Incident Timeline (August 12, 2025)
Key Incident Indicators
Detection Signatures and Artifacts
Network and Endpoint Activities
IAM Audit Findings
Network Block Lists
Checkout Failure Codes
Containment and Response Procedures
API Throttling Playbooks
Partner OAuth Review Procedures
Appendices and Additional Data

Introduction

This document provides a comprehensive summary of the incident that occurred on August 12, 2025. The report consolidates the timeline of events, key indicators identified during threat hunting, detection signatures, artifacts from endpoint detection and response (EDR), IAM audit logs, network block lists, and checkout failure codes. This template facilitates clarity in incident communication, supports external reporting, and aids in post-incident analysis for prevention of similar future events.

Incident Overview

On August 12, 2025, multiple anomalous activities were detected across organizational systems, indicative of a sophisticated multi-vector attack involving command-and-control (C2) operations, exfiltration attempts, and credential compromises. The incident involved unauthorized endpoint activity, increased alert surges, and IAM anomalies that prompted immediate incident response procedures.

The primary objectives of this report are to:

- Chronologically summarize the incident escalation.
- Identify key indicators and signs of compromise.
- Present detection signatures and artifacts used during investigation.
- Outline containment, mitigation, and recovery steps undertaken.

The incident underscores the importance of continuous monitoring, signature-based detection, and incident response readiness.

Incident Timeline (August 12, 2025)

The timeline below details critical events during the incident, highlighting detection points, intervention steps, and escalation moments.

Time (UTC)	Event Description	Source / Detection Method	Action Taken
00:15	Detection of surge in alert activity related to C2 communication	SIEM alert, BEACON-12xx signature match	Initiated incident response protocol
00:30	Unusual MFA failure spikes observed on admin accounts	IAM audit logs, MFA failure logs	Isolated affected user accounts and activated additional safeguards

01:00	Endpoint infection confirmed via mshta.exe and encoded PowerShell commands	EDR artifacts, SHA256 hashes: `abc123...`	Quarantined affected endpoints and collected forensic data
02:15	Outbound network connections to suspicious domains observed	Firewall logs, domain c2-host-01.example	Network blocks implemented; further investigation initiated
03:00	Detected exfiltration attempts via network traffic analysis	Data loss prevention (DLP) alerts	Blocked outbound traffic, halted data exfiltration
Throughout 04:00	Incident containment measures executed including account suspension and network isolation	Incident response playbook	Confirmed containment success

Key Incident Indicators

The following indicators were key in detecting and validating the incident:

Alert Surges

- Spike of BEACON-12xx signature alerts indicating abnormal outbound C2 communication.
- Multiple concurrent detections of suspicious DNS queries associated with C2 domains (e.g., c2-host-01.example).

Multi-Factor Authentication (MFA) Failures

- Unusual MFA failure rates on enterprise admin accounts, particularly involving service accounts with scope ID `SCOPE-PROD-API-ADMIN`.

- Pattern of failed login attempts correlated with internal anomalies.

Endpoint Infections

- Presence of malicious executable `mshta.exe` executing encoded PowerShell commands.
- SHA256 hash matches indicating known malicious payloads (e.g., `abcdef1234567890...`)

Network Exfiltration Indicators

- Connections to known malicious ASN `ASN-64512` associated with exfiltration activity.
- Outbound data volume spikes to suspicious IP ranges and domains such as `c2-host-01.example`.

Checkout Failures

- Checkout process failures with codes `PAY-408`, `GATEWAY-52`, and `CART-ERR-1203` signified attempted fraud or system overload attempts.
- Patterns indicating attack-induced transaction failures on payment gateways.

Detection Signatures and Artifacts

Signature Signatures

- **BEACON-12xx:** Network signature matching outbound beacon signals commonly used by adversaries for command and control. Example pattern: ``
- **C2-DNS-30xx:** DNS query signatures indicative of malicious domain lookup activity used in data exfiltration. Example: ``

EDR Artifacts

Key artifacts identified during endpoint investigation:

- **mshta.exe** executing encoded PowerShell commands with patterns such as:

```
powershell -encodedCommand iVBORw0KGgoAAAANSUhEUgAA...
```

SHA256 hashes of malicious payloads:

- abc123def4567890abc123def4567890abc123def4567890abc123def45678

Additional Signatures

- Process creation of suspicious command lines with signed artifacts such as `powershell.exe -encodedCommand`.
 - Registry modifications associated with persistence mechanisms.
-

Network and Endpoint Activities

Network Activity

Analysis of network logs revealed:

- Connections to known malicious domains such as `c2-host-01.example`.
- Communication with ASN `ASN-64512`, frequent DNS queries to malicious TLDs.
- Data exfiltration signals through abnormal large outbound transfers.

Endpoint Artifacts

Investigation confirmed the presence of the following artifacts on affected endpoints:

- Malicious scripts executing via `mshta.exe`.
 - Encrypted payloads captured with SHA256 hash `abc123def4567890`.
 - Suspicious scheduled tasks created for persistence.
-

IAM Audit Findings

IAM logs included notable anomalies during the incident, such as:

- Automatic creation of service accounts with elevated privileges, specifically related to the event scope `SCOPE-PROD-API-ADMIN`.
- Unusual scope IDs associated with API access patterns. Example scope IDs include:
 - `SCOPE-PROD-API-ADMIN`
 - `SCOPE-PROD-API-READONLY`

- Multiple failed login attempts from ASN ASN-64512 with mismatched IP geolocation.

The IAM findings contributed significantly to identifying compromised components and misused credentials.

Network Block Lists

Throughout the incident, various domains and IP ranges were flagged and blocked as part of containment strategy:

Type	Identifier	Description	Blocking Status
Domain	c2-host-01.example	Malicious command and control host	Blocked
IP Range	192.168.12.0/24	Suspicious internal segment involved in exfiltration	Isolated
ASN	ASN-64512	ASN associated with threat actors	Monitored

Checkout Failure Codes

Multiple checkout failure events were logged during the incident, indicating possible payment fraud attempts or system overloads:

Code	Description	Associated Scenarios
PAY-408	Request Timeout	High load or attack fatigue during checkout
GATEWAY-52	Gateway Error / Service Unavailable	Backend overload or throttling

CART- ERR-1203	Cart processing failure	Potential injection or malicious transaction attempt
-------------------	-------------------------	---

These failure codes were analyzed to understand attack patterns and to improve resilience against automated fraud attempts.

Containment and Response Procedures

Initial Containment Steps

1. Isolate affected endpoints identified by EDR artifacts.
2. Block malicious network domains and IP ranges detected in logs.
3. Suspend compromised user accounts, especially those exhibiting MFA failure anomalies.
4. Apply temporary API throttling to prevent further exfiltration or abuse.

Remediation Steps

- Remove malicious scripts and artifacts from endpoint systems.
- Reset affected credentials and enforce MFA re-registration.
- Update and deploy signatures for BEACON and C2 DNS patterns.
- Conduct thorough forensic analysis to identify root cause.

Communication

Notify relevant stakeholders and partner organizations. Document decisions and actions in incident response logs.

API Throttling Playbooks

Purpose

Reduce attack surface and prevent exfiltration or abuse via aggressive API rate limits during incident escalation.

Procedure

1. Identify critical API endpoints under attack.
2. Apply rate limiting policies to suspect endpoints based on traffic

analysis.

3. Monitor for reduced attack activity and potential false positives.
4. Gradually restore normal limits once threat is mitigated.

Implementation Example

```
POST /api/v1/checkout
Headers:
Authorization: Bearer
Rate Limit: 50 requests per minute (during incident)
```

